

Summative Lab: Operation Silent Shadow

Student Name: [Solomon Mwaura]

Date: February 11, 2026

Analyze the Attack Phases and TTPs

Step 1: Initial Access Summary of Actions Taken by the Attacker: The attackers initiated the campaign by targeting specific employees with phishing emails containing malicious attachments. The attack relied on user interaction; when employees opened the attachments, the malicious payload executed and installed a backdoor, establishing the initial foothold on the network.

Identified TTPs:

- **TTP ID: T1566.001**
 - **Description: Phishing: Spearphishing Attachment.** The adversary sent emails with a malicious file attached to gain access to victim systems.
- **TTP ID: T1204.002**
 - **Description: User Execution: Malicious File.** The adversary relied on the user opening the malicious attachment to run the attack code.

Step 2: Persistence and Privilege Escalation Summary of Actions Taken by the Attacker: To maintain access even if the system was rebooted, the attackers configured a persistent service on the compromised machines. To gain higher-level access, they utilized credential dumping techniques to extract account login information, likely targeting administrator accounts to broaden their control.

Identified TTPs:

- **TTP ID: T1543.003**
 - **Description: Create or Modify System Process: Windows Service.** The attackers created or modified a Windows service to ensure their malware restarts automatically upon system reboot.
- **TTP ID: T1003.001**
 - **Description: OS Credential Dumping: LSASS Memory.** The attackers dumped credentials from memory (e.g., using tools like Mimikatz) to obtain account hashes or plaintext passwords for privilege escalation.

Step 3: Defense Evasion and Credential Access Summary of Actions Taken by the Attacker: The attackers utilized PowerShell scripts, a "Living off the Land" technique, to execute commands in memory and evade traditional antivirus detection. They then leveraged

the credentials harvested in the previous phase to move laterally across the network, logging into other systems as valid users to reach the Ministry's critical servers.

Identified TTPs:

- **TTP ID: T1059.001**
 - **Description: Command and Scripting Interpreter: PowerShell.** The attackers used PowerShell commands/scripts to perform actions, which helps evade detection as it is a legitimate system administration tool.
- **TTP ID: T1078**
 - **Description: Valid Accounts.** The attackers used the compromised credentials to bypass access controls and move laterally, appearing as legitimate user traffic.

Step 4: Exfiltration and Impact Summary of Actions Taken by the Attacker: Having reached their objectives, the attackers stole sensitive data, sending it out to a remote Command and Control (C2) server. To further damage the Ministry, they executed a destructive payload that encrypted critical files, disrupting operations and rendering data inaccessible.

Identified TTPs:

- **TTP ID: T1041**
 - **Description: Exfiltration Over C2 Channel.** The attackers transferred sensitive data out of the network over the existing command and control channel.
 - **TTP ID: T1486**
 - **Description: Data Encrypted for Impact.** The attackers encrypted data on target systems to interrupt availability (ransomware or wiper behavior).
-

Identify the Threat Actor

Step 5: Threat Actor Attribution Threat Actor Group Identified: **Sandworm Team (Also known as Voodoo Bear, IRIS, Telebots)**

Supporting Analysis: I attribute this attack to the **Sandworm Team**, a Russian state-sponsored threat group (associated with the GRU). This attribution is based on the specific combination of espionage and destructive TTPs:

1. **Targeting:** Sandworm is notorious for targeting government entities and critical infrastructure (e.g., Ukraine's power grid and government ministries).
2. **Destructive Impact (T1486):** Unlike many espionage groups (like APT29) that try to remain invisible, Sandworm is unique for combining espionage with destructive encryption attacks (e.g., NotPetya, Olympic Destroyer). The scenario's mention of "encrypting critical files" after exfiltration is a hallmark of Sandworm's "wiper" operations.

3. **Tooling:** They heavily utilize **Spearphishing attachments (T1566.001)** for entry and **PowerShell (T1059.001)** for lateral movement and evasion, which aligns perfectly with the scenario.
-

Recommend Mitigation Strategies

Step 6: Mitigation

Mitigation Strategies for Initial Access and Execution:

- **Email Sandboxing:** Implement an email gateway solution that detonates attachments in a safe sandbox environment before they reach the user (Mitigates T1566).
- **Disable Macros:** Configure Group Policy to block macros from running in Office documents originating from the internet (Mitigates T1204).

Mitigation Strategies for Persistence and Privilege Escalation:

- **Restrict Service Creation:** Limit the privileges required to create or modify services to System Administrators only and monitor Event ID 7045 (Service Installation) (Mitigates T1543).
- **Credential Guard:** Enable Windows Defender Credential Guard to virtualize the LSASS process, preventing tools like Mimikatz from dumping credentials (Mitigates T1003).

Mitigation Strategies for Defense Evasion and Credential Access:

- **PowerShell Logging:** Enable PowerShell Script Block Logging (Event ID 4104) to capture and analyze the actual code being executed, even if it is obfuscated (Mitigates T1059).
- **Network Segmentation:** Segregate the network into zones so that valid credentials from a workstation cannot be used to RDP directly into critical servers (Mitigates Lateral Movement).

Mitigation Strategies for Exfiltration and Impact:

- **Data Loss Prevention (DLP):** Implement DLP rules to detect and block the transfer of sensitive data to unrecognized external IP addresses (Mitigates T1041).
 - **Offline Backups:** Maintain isolated, offline backups of critical data. While this does not prevent encryption (T1486), it is the only fail-safe method to restore operations without paying a ransom or losing data permanently.
-

Conclusion

Operation Silent Shadow bears the distinct signature of the **Sandworm Team**, characterized by a sophisticated kill chain that began with spearphishing and culminated in a destructive encryption event. The attackers successfully leveraged "Living off the Land" techniques like PowerShell to evade detection and moved laterally using valid credentials. To defend against future attacks, the Ministry of Foreign Affairs must prioritize **Credential Guard** to stop privilege escalation and **Offline Backups** to ensure resilience against destructive data impacts. Implementation of these controls will significantly raise the cost of entry for future adversaries.